



FACULDADE DE
CIÊNCIAS E TECNOLOGIA
UNIVERSIDADE DE
COIMBRA



Fundamentos de Segurança Informática

Trabalho Prático 1

Relatório

Data: 22/03/2026

Trabalho realizado no âmbito da edição de 2025/2026 da disciplina de Fundamentos de Segurança Informática, da responsabilidade do docentes António Jorge da Costa Granjal, Rogério Luís de Carvalho Costa do Departamento de Engenharia Informática, da Licenciatura em Engenharia Informática da Faculdade de Ciências e Tecnologias da Universidade de Coimbra pelos alunos Luís Filipe Cardetas Banha – nº2023217305 e Rui Mário Teixeira Camarão – nº2023216522 da turma PL5.

Scripts de configuração

Para configurar o cenário do Trabalho foram usados vários scripts de configuração, um para cada área no problema, estes scripts configuram as interfaces necessárias, e desativam a interface NAT da VM, para evitar o uso de várias VMs, ou múltiplas reconfigurações das interfaces fez uso de ip aliases que permite a uma interface ter vários ips.

Descrição das Configurações (Filtros e NAT)

A firewall foi configurada com a política base de dar DROP aos pacotes que entram no router, ou seja nas chains INPUT e FORWARD. Também foi adicionada a regra que permite a entrada de pacotes com o estado de ligação ESTABLISHED e RELATED.

Proteção do router: O acesso direto ao router foi limitado. Permitiu-se apenas a resolução DNS para o exterior e ligações SSH exclusivamente da rede interna e do gateway VPN (*vpn-gw*).

Comunicações Diretas (Sem NAT): Permitiu-se resoluções de nome para o servidor dns, tal como a sincronização do servidor dns com dns2. Permitiu-se ainda o acesso aos vários serviços na dmz. E por fim permitiu-se o acesso à rede interna de tráfego proveniente do *vpn_gw*.

Configurações NAT:

DNAT: O tráfego ftp com destino ao ip exterior do router foi redirecionado para o servidor FTP na rede interna, com o devido carregamento de módulos *conntrack* de FTP para suportar modos ativo e passivo. Também foram redirecionados os pacotes ssh com destino ao ip exterior do router para o ip da datastore, mas só se os pacotes forem provenientes dos servidores dn2 ou eden.

SNAT: Os ips do tráfego da rede interna é substituído com o ip do router , com a restrição de ser tráfego DNS, HTTP, HTTPS, SSH e FTP.

Deteção e Prevenção de Intrusões (Suricata)

De forma a permitir que o Suricata analise e bloqueie ativamente ataques, todo o tráfego avaliado pelas chains INPUT e FORWARD foi reencaminhado para a NFQUEUE, permitindo a inspeção em tempo real e aplicação de mecanismos de deteção e prevenção de intrusões.

Foram definidas várias regras personalizadas (*local rules*) com o objetivo de identificar e bloquear padrões típicos de ataques comuns, como *port scanning*, *SQL Injection (SQLi)* e *Cross-Site Scripting (XSS)*.

Deteção de Port Scanning:

Foi criada uma regra para detetar tentativas de varrimento de portas, analisando pacotes TCP com flag SYN. Caso um mesmo endereço de origem envie 20 pacotes num intervalo de 5 segundos, o tráfego é considerado suspeito e bloqueado.

```
drop tcp any any -> $HOME_NET any (msg:"PORT SCAN detected"; flags:S; threshold:type threshold, track by_src, count 20, seconds 5; sid:1000001; rev:1;)
```

Deteção de SQL Injection (SQLi):

Foram implementadas regras para identificar padrões comuns de injeção SQL:

- Padrão "OR 1=1", frequentemente usado para contornar autenticação:

```
drop http any any -> $HOME_NET any (msg:"SQLi Attempt (OR 1=1 Pattern)"; http.uri; content:"OR"; nocase; pcre:"/[\"'s]*OR\s*[\"']?\d[\"']?\s*=\s*[\"']?\d/UI"; sid:1000002; rev:1;)
```

- Padrão "SELECT ... FROM", indicativo de tentativa de extração de dados:

```
drop http any any -> $HOME_NET any (msg:"SQLi Attempt (SELECT FROM Pattern)"; content:"SELECT"; nocase; http_uri; content:"FROM"; nocase; http_uri; pcre:"/SELECT.*\bFROM\b/UI"; sid:1000003; rev:1;)
```

Deteção de Cross-Site Scripting (XSS):

Foram também consideradas tentativas de injeção de scripts em pedidos HTTP:

- Uso da tag <script>:

```
drop http any any -> $HOME_NET any (msg:"XSS attempt script tag"; content:"<script>"; nocase; http_uri; sid:1000004; rev:1;)
```

- Uso da função <script>:

```
drop http any any -> $HOME_NET any (msg:"XSS attempt alert()"; content:"alert("; nocase; http_uri; sid:1000005; rev:1;)
```

Estas regras utilizam a ação drop, funcionando como um sistema de prevenção de intrusões (*IPS*), bloqueando ativamente o tráfego malicioso.

Testes de validação

Para validar as regras de firewall de proteção do router e de comunicações, foi usado o utilitário netcat e clientes ssh.

HTTP, HTTPS e dns: Em um dos extremos foi executado o nc como servidor(ex: nc -l <ip> <porta>) nos portos necessários para os serviços, e no extremo oposto usou-se como cliente(ex: nc <ip_destino> <porta> ou com -s <ip_cliente>) para confirmar a validade das regras.

SSH: Recorreu-se ao comando ssh <ip> para verificar as regras de ssh.

DNAT: Para verificar se DNAT estava a ocorrer recorreu-se ao utilitário tcpdump para capturar o tráfego de entrada no destino na “internet” e verificou-se que o source ip correspondia ao da interface exterior do router

FTP: Para a verificação das regras de ftp, instalou-se o serviço vsftpd para poder usar a VM como servidor ftp, do lado do cliente usou-se o cliente ftp e verificou-se que ambos os modos passavam pelas regras que era suposto.

Regras suricata: Para testar a deteção de intrusões, usou-se o utilitário nmap com nmap -sS -T4 -p 1-100 <ip_router> para realizar um portscan, as outras regras foram testadas usando python3 -m http.server --bind <ip> para atuar como servidor e foi usado um browser para realizar os ataques de SQL injection e xss. Através do ficheiro /var/log/suricata/fast.log verificou-se a deteção de todos os ataques.